

ACTA DE ENTREGA-RECEPCIÓN

Playbook 2 de 18 - Hardening CIS Microsoft Windows Server 2025

Acta N.º	_____ (completar)	Fecha de elaboración	8 de octubre de 2026
Cliente	Banco Solidario	Proveedor	GMS - Práctica Red Hat / Ansible
Proyecto	Desarrollo de 18 Playbooks de automatización con Ansible/AWX	Playbook entregado	N.º 2 - CIS Windows Server 2025 Benchmark v2.1.0, Nivel 1 + Nivel 2, Member Server
Repositorio	github.com/Soporte-SI/HARDENING-WINDOWS-SERVER-2025 (rama main)	Commit / etiqueta entregada	Código Completado

1. Objeto del acta

Mediante la presente acta, GMS hace entrega formal a Banco Solidario del **Playbook 2 - Hardening CIS Windows Server 2025**, desarrollado como parte del proyecto de 18 playbooks de automatización con Ansible, junto con su código fuente, documentación y matriz de cobertura, y Banco Solidario deja constancia de su recepción conforme al detalle descrito a continuación.

2. Objetivo del playbook

Aplicar de forma **automatizada, repetible y auditable**, sobre servidores Windows Server 2025 (perfil **Member Server**) y a través de WinRM, los controles del **CIS Microsoft Windows Server 2025 Benchmark v2.1.0** (Nivel 1 + Nivel 2) correspondientes a políticas de cuenta, políticas locales y opciones de seguridad, servicios, firewall, auditoría avanzada y plantillas administrativas, con selección de secciones al lanzar el job (Survey de AWX) y excepciones documentadas por control.

3. Alcance y cobertura entregada

Sección CIS	Tema	Controles en la matriz
1	Políticas de cuenta (contraseñas y bloqueo)	11
2	Políticas locales (derechos de usuario y opciones de seguridad)	118
5	Servicios del sistema	2
9	Firewall de Windows Defender	23
17	Política de auditoría avanzada	34
18	Plantillas administrativas (equipo)	231
19	Plantillas administrativas (usuario)	11
Total	Secciones 1, 2, 5, 9, 17, 18 y 19	430

Estado en la matriz de cobertura	Cantidad	Significado
implemented	333	Automatizados por el rol: 270 de Nivel 1 + 63 de Nivel 2.
excluded_baseline_cliente	55	No figuran en la línea base entregada por el banco (Linea_Base_Hardening_CIS_WindowsServer2025_Final.xlsx); el código se conserva con el toggle deshabilitado.
not_applicable	37	Aplican solo a Controlador de Dominio (el perfil entregado es Member Server) u otros casos no aplicables.

Estado en la matriz de cobertura	Cantidad	Significado
manual	5	Requieren verificación humana o un valor específico del entorno; se documentan con nota por ID.
Total	430	Cada control aparece una vez en docs/coverage_matrix.csv.

Fuera de alcance de esta iteración: las secciones 3, 4, 6, 7, 8 y 10 a 16 del benchmark (Event Log, Restricted Groups, ACLs, Wired/Wireless, AppLocker, etc.) no fueron extraídas y no están en la matriz; son trabajo futuro.

Nota: el README del repositorio conserva cifras de una iteración anterior (428 controles / 380 implementados); la matriz de cobertura es la fuente vigente de esta acta.

4. Lógica de funcionamiento

El rol carga todos los datos de control, decide qué secciones ejecutar y aplica cada control mediante el módulo Windows apropiado. Cada tarea respeta dos compuertas: el **nivel CIS** y el **toggle individual** del control; además, los controles que podrían cortar la conexión WinRM quedan en una lista de PENDIENTES que no se aplica por defecto.



Mecanismos de control

Mecanismo	Cómo funciona
Nivel CIS	win2025cis_level: 1 = solo Nivel 1; 2 = Nivel 1 + Nivel 2 (valor por defecto).
Toggle por control	Un booleano win2025cis_rule_<id> por control implementado; se sobrescribe en group_vars/host_vars o con -e para excluir exactamente ese control.
Selección de secciones	win2025cis_secciones (lista) permite ejecutar solo ciertas secciones; en AWX se elige con el Survey docs/awx_survey_secciones.json.
PENDIENTES (riesgo WinRM)	Controles que dejarían a Ansible sin conexión (p. ej. 18.10.90.2.2, deshabilitar WinRM remoto) no se aplican por defecto; se pueden aplicar bajo demanda con win2025cis_aplicar_pendientes.
OBSERVACIONES	Controles aplicados que quedan anotados para revisión posterior del equipo de seguridad.
Tags	Por sección (section1, section17...) y por control. Un tag de control ejecuta el loop completo al que pertenece; para excluir un solo control se usa su toggle.
Modo simulación	--check --diff: válido para registro, servicios, derechos y auditoría; secdit (secciones 1 y 2) tiene soporte limitado, validar en no productivo.
Orden de aplicación	Las políticas de bloqueo (1.2.x) se aplican en un orden que respeta la regla de Windows 'duración >= restablecer contador'; los nombres de subcategorías de auditoría (17.x) fueron verificados con auditpol /list en el servidor real.

5. Diagrama de archivos del repositorio

```
HARDENING-WINDOWS-SERVER-2025/
|-- site.yml                # Entry point: play sobre [windows] + rol
|-- ansible.cfg             # Config (incluye plugin de inventario "script" para AWX)
|-- requirements.yml        # ansible.windows, community.windows
|-- test_conexion.yml       # Diagnóstico WinRM (win_ping), sin cambios
|-- README.md
|-- inventory/
|   |-- hosts.example.ini   # Plantilla WinRM (HTTPS 5986, NTLM/CredSSP)
|   |-- lab/               # Inventario temporal de laboratorio
|       |-- hosts.ini
|       |-- group_vars/windows.yml
|-- group_vars/
|   |-- windows.yml        # Nivel CIS + ejemplos de excepción
|-- docs/
|   |-- coverage_matrix.csv # 430 controles con estado y notas
|   |-- awx_survey_secciones.json # Survey de AWX: secciones a ejecutar
|-- roles/win2025_cis_hardening/
|   |-- meta/main.yml
|   |-- defaults/main.yml  # Nivel, valores de la org, secciones, pendientes, toggles
|   |-- handlers/main.yml  # gpupdate /force
|   |-- tasks/
|       |-- main.yml        # Orquestador + resumen final
|       |-- section1_account_policies.yml
|       |-- section2_local_policies_security_options.yml
|       |-- section5_system_services.yml
|       |-- section9_firewall.yml
|       |-- section17_advanced_audit_policy.yml
|       |-- section18_administrative_templates_computer.yml
|       |-- section19_administrative_templates_user.yml
|   |-- vars/              # Datos por sección (id, nivel, clave/valor)
|       |-- section1/2/5/9/17/18/19 (*.yaml)
```

6. Función de cada archivo

Archivos de raíz, inventario y documentación

Archivo	Función
site.yml	Play sobre el grupo windows con gather_facts; ejecuta el rol.
ansible.cfg	Inventario, roles_path, host_key_checking desactivado y plugins de inventario habilitados (incluye script, necesario para el inventario dinámico de AWX).
requirements.yml	Colecciones ansible.windows y community.windows (>= 2.0.0).
test_conexion.yml	Prueba de conectividad WinRM con win_ping; no aplica cambios. Úsese como Job Template de verificación previa.
inventory/hosts.example.ini	Plantilla de conexión WinRM (HTTPS 5986). Contiene una credencial de laboratorio de ejemplo: no usarla en producción; usar Ansible Vault o un Credential de AWX.
inventory/lab/*	Inventario temporal del laboratorio de hardening (servidor fuera de dominio).
group_vars/windows.yml	Nivel CIS (2) y ejemplos comentados de excepciones por control.
docs/awx_survey_secciones.json	Definición del Survey de AWX para elegir qué secciones CIS ejecutar al lanzar el job.
docs/coverage_matrix.csv	Matriz de cobertura de los 430 controles con estado, tag y notas.
README.md	Alcance, requisitos, configuración WinRM, ejecución, exclusiones y advertencias.

Rol win2025_cis_hardening - tareas

Archivo	Sección CIS	Qué hace
tasks/main.yml	-	Carga vars/, muestra secciones activas, incluye cada sección condicionada a win2025cis_secciones y emite el resumen de PENDIENTES/OBSERVACIONES.
section1_account_policies.yml	1	Política de contraseñas y bloqueo de cuenta vía secedit (win_security_policy).
section2_local_policies_security_options.yml	2	Derechos de usuario, opciones de seguridad (secdit y registro) y renombrado de cuentas Administrator/Guest.
section5_system_services.yml	5	Estado e inicio de servicios del sistema.
section9_firewall.yml	9	Propiedades de los perfiles Domain/Private/Public del Firewall de Windows Defender.
section17_advanced_audit_policy.yml	17	Subcategorías de auditoría avanzada (win_audit_policy_system / auditpol).
section18_administrative_templates_computer.yml	18	Plantillas administrativas de equipo escritas directamente en el registro (HKLM).
section19_administrative_templates_user.yml	19	Plantillas administrativas de usuario en HKU:\.DEFAULT (aplican a nuevos inicios de sesión).

Rol - variables, handlers y metadatos

Archivo	Función
defaults/main.yml	Nivel CIS, valores de la organización (nombres de cuentas renombradas, banner legal, rutas de log del firewall), selección de secciones, listas de PENDIENTES y OBSERVACIONES, y un toggle por control.
vars/section*.yml	Datos estructurados por sección (id, nivel, ruta/valor de registro, derecho, subcategoría). Las tareas solo iteran sobre estas listas.
handlers/main.yml	Ejecuta gpupdate /force cuando cambian políticas de grupo/registro.
meta/main.yml	Metadatos del rol.

7. Uso y ejecución

Requisitos: control node con ansible-core >= 2.15 y pywinrm; colecciones de requirements.yml; hosts Windows Server 2025 con listener WinRM HTTPS (5986) y una cuenta con permisos de administrador local.

```
ansible-galaxy collection install -r requirements.yml
cp inventory/hosts.example.ini inventory/hosts.ini # ajustar host y credenciales (vault)

# 0) Verificar conectividad WinRM (sin cambios)
ansible-playbook -i inventory/hosts.ini test_conexion.yml

# 1) Simulación
ansible-playbook -i inventory/hosts.ini site.yml --check --diff

# 2) Aplicación completa (Nivel 1 + 2, todas las secciones)
ansible-playbook -i inventory/hosts.ini site.yml

# 3) Solo Nivel 1 / solo algunas secciones / excluir un control
ansible-playbook -i inventory/hosts.ini site.yml -e win2025cis_level=1
ansible-playbook -i inventory/hosts.ini site.yml -e '{"win2025cis_secciones": ["1", "17"]}'
ansible-playbook -i inventory/hosts.ini site.yml -e win2025cis_rule_2_3_1_3=false
```

En AWX, las secciones a ejecutar se eligen con el Survey cargado desde docs/awx_survey_secciones.json (variable win2025cis_secciones).

8. Consideraciones y advertencias de operación

- **Probar primero en no productivo.** Los controles de NTLM/LAN Manager, RDP y firewall pueden dejar sin acceso remoto a un servidor mal configurado.
- **Conexión de Ansible.** La cuenta de servicio usada por WinRM debe estar desbloqueada y con el transporte correcto (NTLM/Kerberos/CredSSP); los controles que cortarían WinRM están en PENDIENTES y no se aplican por defecto.
- **Reinicio y gpupdate.** Algunos controles (UAC, protección de LSA, Kerberos/Netlogon) requieren reinicio; la sección 19 aplica solo a nuevos inicios de sesión.
- **GPO en dominio.** Si existe una GPO competidora, sobrescribirá estos valores en su siguiente ciclo; en un entorno AD se recomienda entregar el benchmark también por GPO.
- **Credenciales.** No usar la credencial de laboratorio del inventario de ejemplo; gestionar usuario/contraseña con Ansible Vault o un Credential de AWX.
- **Cobertura.** Solo las secciones 1, 2, 5, 9, 17, 18 y 19 del benchmark están cubiertas en esta entrega.

9. Entregables

N.º	Entregable	Conforme
1	Código fuente del playbook (site.yml, rol win2025_cis_hardening, inventario de ejemplo, variables) en el repositorio indicado	[]
2	Matriz de cobertura de 430 controles (docs/coverage_matrix.csv) y Survey de AWX (docs/awx_survey_secciones.json)	[]
3	Playbook de diagnóstico de conectividad WinRM (test_conexion.yml)	[]
4	README con requisitos, configuración WinRM, ejecución, exclusiones y advertencias	[]
5	Explicación de la lógica y diagrama de archivos (esta acta)	[]

10. Observaciones

11. Conformidad

Las partes declaran haber revisado el contenido de la presente acta y firman en señal de entrega y recepción conforme.

ENTREGA - GMS	RECIBE - BANCO SOLIDARIO
Juan Pablo Castillo Cargo: Líder de Proyecto Fecha de elaboración del documento: 8 de octubre de 2026	Jeremy Moreno Cargo: Seguridad de la Información Fecha de elaboración del documento: 8 de octubre de 2026